

1. OVERVIEW

An overview of Requirement 1
("Keep a Firewall"), and its
sub-requirements.



REQ. 1: KEEP A FIREWALL

REQ. 1: KEEP A FIREWALL **OVERVIEW**

Requirement 1 (Install and Maintain Network Security Controls) is about protecting your CDE from network traffic (both inbound and outbound).

- It used to be just about firewalls, and now includes all NSCs;
- In short, it's about making sure that nobody gains undue access to your data through your networks;

This requirement focuses mostly on:

- Having NSC (Network Security Controls), such as firewalls;
- Restricting access to the Card Data Environment;
- Ensuring that connections from untrusted networks or sources are restricted;
- Properly dealing with devices that can both connect to trusted and untrusted networks;

REQ. 1: KEEP A FIREWALL **OVERVIEW**

The sub-requirements for this requirement include:

- 1.1 Processes and mechanisms for installing and maintaining network security controls are defined and understood.
- 1.2 Network security controls (NSCs) are configured and maintained.
- 1.3 Network access to and from the cardholder data environment is restricted.
- 1.4 Network connections between trusted and untrusted networks are controlled.
- 1.5 Risks to the CDE from computing devices that are able to connect to both untrusted networks and the CDE are mitigated.





REQ.1: KEEP A FIREWALL

REQ. 1: KEEP A FIREWALL **OVERVIEW**

1.1 Processes and mechanisms for installing and maintaining network security controls are defined and understood

- This is a sub-requirement we will see in all requirements. Everything done to comply must be documented, kept up to date, in use, and known to everyone relevant;
- The relevant roles and responsibilities for these activities must also be documented, assigned, understood;

This is usually tested through:

- Examining the documentation and interviewing personnel to ensure all processes and methodologies are documented and enforced;
- Verifying that details, job descriptions, others are accurate;

REQ. 1: KEEP A FIREWALL

OVERVIEW

1.2 Network security controls (NSCs) are configured and maintained. This sub-requirement has two main areas:

- One is about configuration. Rulesets must be defined, the same for all equipment, implemented for any new NSC. Changes must be approved and config files secured;
- Then, we must have two diagrams. A network diagram showing all CDE connections and a data flow diagram showing CHD data flows across systems and networks;

This is usually tested through:

- Examining the configuration standards, the processes for configuring new NSCs, the processes for changing configs;
- Verifying the existence - and accuracy - of the diagrams;





REQ.1: KEEP A FIREWALL

REQ. 1: KEEP A FIREWALL **OVERVIEW**

1.3 Network access to and from the cardholder data environment is restricted

- Basically, we want to deny all the traffic that we can - inbound and outbound - to and from the CDE. We want to completely isolate it and only allow essential traffic;
- Firewalls/NSCs must exist between the CDE and all wireless networks, to ensure that all traffic is denied by default;

This is usually tested through:

- Examining NSC configuration files to ensure inbound and outbound traffic are both denied by default;
- Examining standards and diagrams to ensure there are NSCs at all junctures between networks and the CDE;

REQ. 1: KEEP A FIREWALL **OVERVIEW**

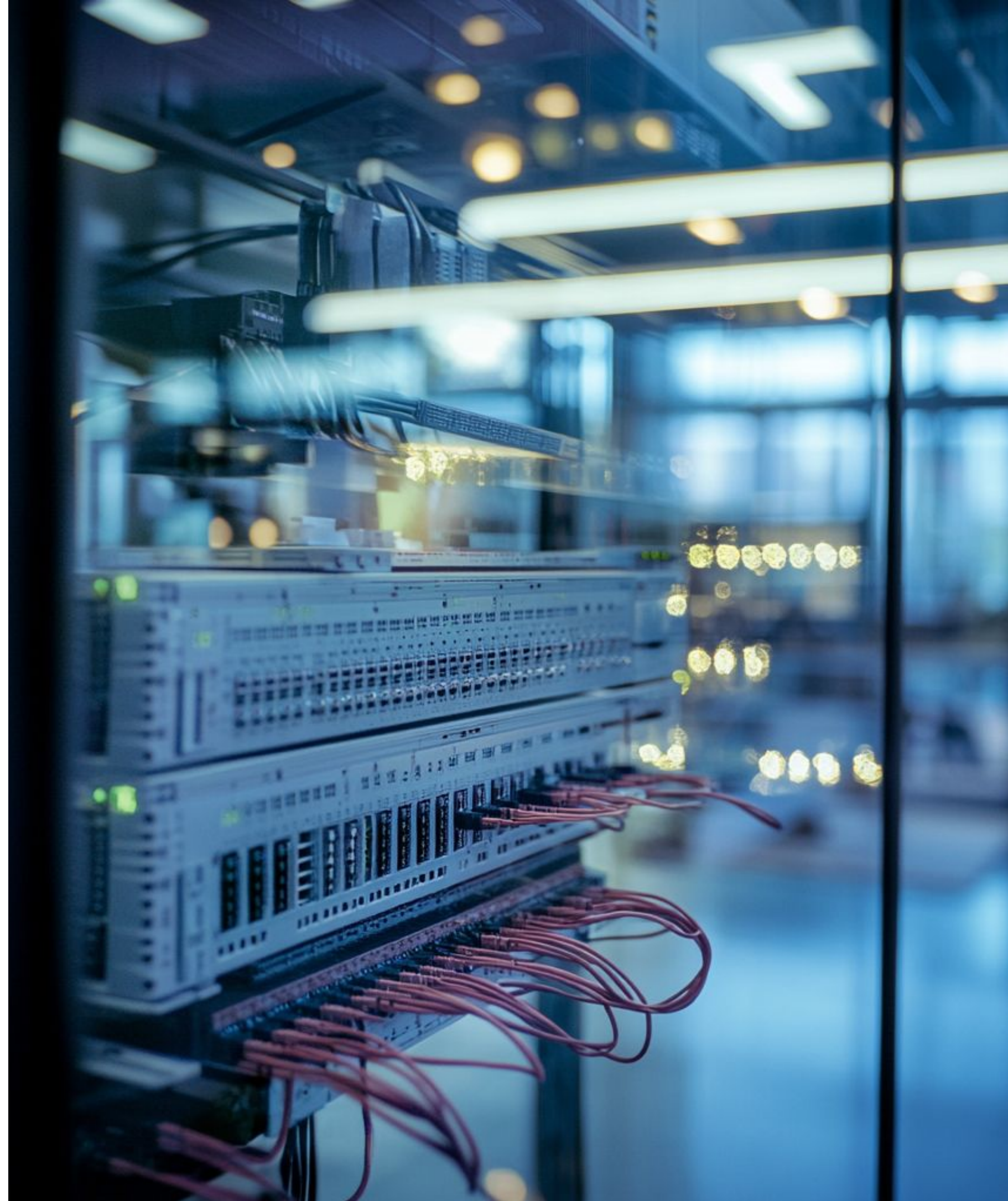
1.4 Network connections between trusted and untrusted networks are controlled

- This sub-requirement is about ensuring that untrusted networks cannot be a problem. They are separated from trusted networks with NSCs, all traffic except public services/data is denied, anti-spoofing is implemented, and components with CHD should not be directly accessible;
- In v3 we had a “DMZ” - not anymore. Just need separation;

This is usually tested through:

- Examining the presence of NSCs between trusted and untrusted networks, as well as verifying that inbound traffic from untrusted networks really is restricted;
- Examining diagrams to ensure CHD isn't directly accessed;





REQ.1: KEEP A FIREWALL

REQ. 1: KEEP A FIREWALL **OVERVIEW**

1.5 Risks to the CDE from computing devices that are able to connect to both untrusted networks and the CDE are mitigated

- Both the company and employees may have devices which may become infected or compromised;
- So, all devices that connect to the CDE must have security controls on them that are updated, cannot be turned off, and configured in a standardized manner;

This is usually tested through:

- Examining documentation of the security controls for these devices - as well as the presence of controls on them;
- Examining the configuration settings, and the actual configurations in such devices;

REQ. 1: KEEP A FIREWALL **OVERVIEW**

How can we summarize, then, this requirement?

- We must have firewalls or other NSCs that are maintained, standardize their configurations, and keep diagrams of our networks and data flows through systems/networks;
- Network access to the CDE must be minimized, being denied by default with the use of NSCs, which must be present in all junctures between the CDE and networks;
- We must control connections between trusted and untrusted networks, denying all traffic except publicly available services, applying anti-spoofing measures, and not allowing direct access to CHD;
- We must run standardized, unremovable controls on all devices that connect to the CHD and untrusted networks;



REQ. 1: KEEP A FIREWALL

OVERVIEW

EXAMPLES

/01 RIGOROUS DOCUMENTS

The more rigorous the network topology and the CHD flowchart are, the less vulnerabilities will go unnoticed, and the more protected the CDE is.

/02 OUTBOUND ALSO

Although a lot of firewall admins focus on restricting inbound traffic to prevent attackers, outbound must also be restricted - to prevent exfiltration of info.

/03 DENY BY NATURE

This requirement shares one principle in common with the PCI DSS in general - deny by nature. If there is no justification for a service or open port... block it.

REQ. 1: KEEP A FIREWALL

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization sets up a firewall, protecting the PoS system from unauthorized traffic, and separating it from the customer Wi-Fi;
- The organization replaces default passwords and settings on routers and modems with strong ones,
- The organization limits inbound and outbound traffic to the essential;

E-COMMERCE STORE

- The organization sets up a Web App Firewall (WAF) to shield its online store from common web attacks;
- The organization segments the CDE from the rest of the corporate network, to minimize exposure in case of breach;
- The organization regularly updates and patches all network devices;

HOTEL CHAIN

- The organization adopts an enterprise-grade firewall solution to protect the CDE in all hotel locations;
- The organization segments payment processing systems from guest networks and internal admin networks;
- The organization formalizes firewall policies across all devices and locations;

PAYMENT PROCESSOR

- The organization adopts an advanced next-gen firewall (NGFW), with embedded intrusion detection capabilities;
- The organization implements access control lists to network equipment and protects configuration files with FIM;
- The organization also has real-time monitoring tools;

REQ. 1: KEEP A FIREWALL

OVERVIEW

KEY TAKEAWAYS

/01 KEEPING NSCs

The idea here is to have a firewall, or other NSCs, protecting everything that deals with your CDE, and ensuring it's properly configured and protected.

/03 1.2 CONFIGURING NSCs

NSCs must have clear rulesets and config files, there must be a process to configure them, changes must be approved, and these files protected. And diagrams.

/05 1.4 TRUSTED/UNTRUSTED

We must ensure all traffic from untrusted networks is denied, except for publicly available services/protocols, apply anti-spoofing, and deny direct access to CHD.

/02 1.1 PROCESSES DEFINED

A sub-requirement we will have in all requirements. All processes and procedures must be documented and updated, as well as associated roles/responsibilities.

/04 1.3 RESTRICTING TRAFFIC

We must deny, by default, all inbound and outbound traffic to the CDE, and have firewalls/NSCs at all junctures to ensure this.

/06 1.5 MITIGATING DEVICES

Devices that connect to untrusted networks and the CDE must have standardized, unremovable security controls running on them.